

第六讲 漏洞挖掘与模糊测试

一、漏洞挖掘技术简介

面对着二进制级别的软件，怎样才能错综复杂的逻辑中找到真正的漏洞呢？工业界目前普遍采用的是进行 Fuzz 测试，与基于功能性的测试有所不同，Fuzz 的主要目的是“崩溃 crash”，“中断 break”，“销毁 destroy”。

Fuzz 的测试用例往往是带有攻击性的畸形数据，用以触发各种类型的漏洞。

我们可以把 Fuzz 理解成为一种能自动进行“rough attack”尝试的工具。之所以说它是“rough attack”，是因为 Fuzz 往往可以触发一个缓冲区溢出的漏洞，但却不能实现有效的 exploit。测试人员需要实时地捕捉目标程序抛出的异常、发生的崩溃和寄存器等信息，综合判断这些错误是不是真正的可利用漏洞。

Fuzz 技术的思想就是利用“暴力”来实现对目标程序的自动化测试，然后监视检查其最后的结果，如果符合某种情况就认为程序可能存在某种漏洞或者问题。

这里的“暴力”并不是说我们通常说得武力，而是说利用不断地向目标程序发送或者传递不同格式的数据来测试目标程序的反应。

Fuzz 的测试优点是很少出现误报，能够迅速地找到真正的漏洞；缺点是 Fuzz 永远不能保证系统里已经没漏洞。即使我们用 Fuzz 找到了 100 个严重的漏洞，系统中仍然可能存在第 101 个漏洞。

学术界偏向于对源代码进行静态分析，直接在程序的逻辑上寻找漏洞。

静态分析这一方面的方法和理论有很多，比如数据流分析、类型验证系统、边界检验系统、状态机系统等。

静态代码分析技术的缺点是经常会产生大量的误报——如果分析工具一次产生了上千个漏洞警告，几乎没有人愿意一个一个地去排查。由于黑客们一般情况下是得不到源代码的，所以使用白盒测试方法的以 QA 工程师居多。

	动态测试技术	静态代码审计
主要技术	Fuzz等黑盒测试	数据流分析、类型验证系统、边界检验系统、状态机系统等
主要应用人群	攻击者	学者、QA工程师
优点	快捷，准确	检测出的漏洞数量多
缺点	不能发现系统里全部（或者大部分）漏洞	实现静态代码分析工具相当困难

二、简单的 fuzzing 演示

我们在发现一些溢出漏洞的时候，往往是不断地给目标程序输入不同长度的字符串变量来测试目标程序是不是存在溢出漏洞的。

三、文件类型漏洞挖掘

1、文件格式 Fuzz 的基本方法

攻击者往往会在约定的数据格式进行稍许修改，观察软件在解析这种“畸形文件”时是否会发生错误，缓冲区是否会溢出等。

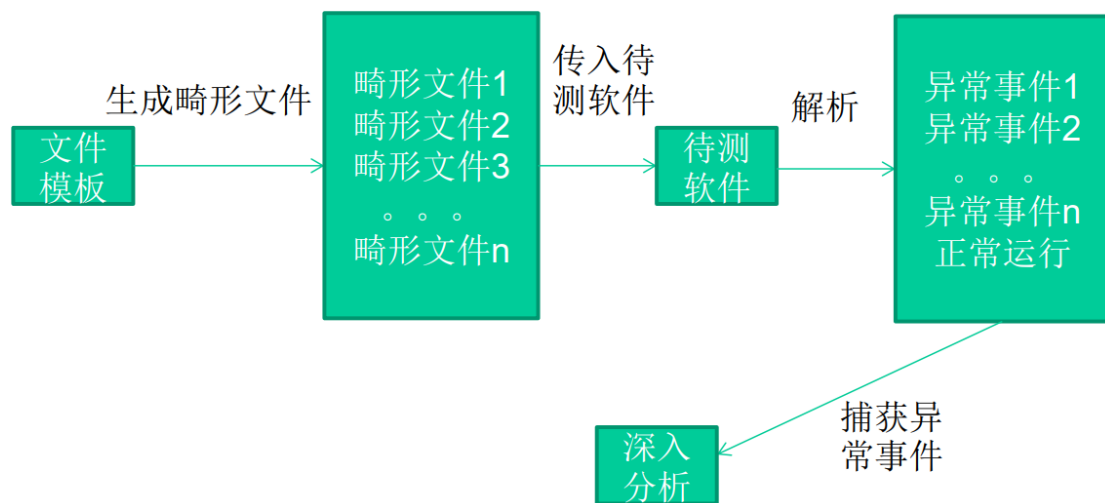
一个 File Fuzz 工具通常包括以下几个步骤：

(1) 以一个正常的文件模板为基础，按照一定规则产生一批畸形文件。

(2) 将畸形文件逐一送入软件进行解析，并监视软件是否会抛出异常。

(3) 记录软件产生的错误信息，如寄存器状态、栈状态等。

(4) 用日志或其他 UI 形式向测试人员展示异常信息，以进一步鉴定这些错误是否能被利用。



2、Blind Fuzz

Blind Fuzz 即通常所说的“盲测”，就是在随机位置插入随机的数据以生成畸形文件。然而现代软件往往使用非常复杂的私有数据结构。

例如 PPT、word、excel、mp3、RMVB、PDF、jpg、ZIP 压缩包，加壳的 PE 文件。数据结构越复杂，解析逻辑越复杂，就越容易出现漏洞。复杂的数据结构通常具备以下特征：

- 1) 拥有一批预定义的静态数据，如 magic, cmd id 等
- 2) 数据结构的内容是可以动态改变的
- 3) 数据结构之间是嵌套的
- 4) 数据中存在多种数据关系(size of, point to, reference of, CRC)
- 5) 有意义的数据被编码或压缩，甚至用另一种文件格式来存储，这些格式的文件被挖掘出来越来越多的漏洞

对于采用复杂数据结构的复杂文件进行漏洞挖掘，传统的 Blind Fuzz 暴露出一些不足之处。例如：产生测试用例的策略缺少针对性，生成大量无效测试用例，难以发现复杂解析器深层逻辑的漏洞等。

3、Smart Fuzz

针对 Blind Fuzz 的不足，Smart Fuzz 被越来越多地提出和应用。通常 Smart Fuzz 包括三方面的特征：面向逻辑(Logic Oriented Fuzzing)，面向数据类型(Data Type Oriented Fuzzing)，基于样本(Sample Based Fuzzing)。

(1) 面向逻辑

测试前首先明确要测试的目标是解析文件的程序逻辑，而不是文件本身。

复杂的文件格式往往要经过多“层”解析，因此还需要明确测试用例正在试探的是哪一层的解析逻辑，即明确测试“深度”以及畸形数据的测试“粒度”。

明确了测试的逻辑目标后，在生成畸形数据时可以具有针对性的仅仅改动样本文件的特定位置，尽量不破坏其他数据一来关系，这样使得改动的数据能够传递到测试的解析深度，而不会在上层的解析器中被破坏。

(2) 面向数据类型测试：

测试中可以生成的数据通常包括以下几种类型：

- 1) 算术型：包括以 HEX、ASCII、Unicode、Raw 格式存在的各种数值。
- 2) 指针型：包括 Null 指针、合法/非法的内存指针等。
- 3) 字符串型：包括超长字符串、缺少终止符(0x00)的字符串等。
- 4) 特殊字符：包括#，@，'，<，>，/，\，../等等。

面向数据类型测试是指能够识别不同的数据类型，并且能够针对目标数据的类型按照不同规则来生成畸形数据。

跟 Blind Fuzz 相比，这种方法产生的畸形数据通常都是有效的，能够大大减少无效的畸形文件。

(3) 基于样本

测试前首先构造一个合法的样本文件（也叫模版文件），这时样本文件里所有数据结构和逻辑必然都是合法的。然后以这个文件为

模板，每次只改动一小部分数据和逻辑来生成畸形文件，这种方法也叫做“变异”(Mutation)。

对于复杂文件来说，以现成的样本文件为基础进行畸形数据变异来生成畸形文件的方法要比上面两种的难度要小很多，也更容易实现。

但是这种方法不能测试样本文件里没有包含的数据结构，比如一个文件格式包含 18 种数据区块(Chunk)，而给定的样本文件中只用到了其中的 10 种，那么基于样本测试的方法只会修改这 10 种区块的数据来产生畸形文件，测试不到其他 8 种数据对应的解析逻辑。

为了提高测试质量，就要求在测试前构造一个能够包含几乎所有数据结构的文件（比如文字、图像、视频、声音、版权信息等数据）来作为样本。

四、FTP 漏洞挖掘

1、FTP 协议简介

FTP 服务全称为文件传输协议服务，英文全称为 File Transfer Protocol，其工作模式采用客户端/服务器的模式，也就是 C/S 模式。

FTP 服务在进行文件信息传输的时候采用 FTP 协议。FTP 协议是基于 TCP 协议之上的一种明文协议。FTP 协议默认情况下工作在 21 号端口，它的具体命令被规定在 RFC0959 当中。

用户从客户端连接远程 FTP 服务程序的过程可以分为建立连接、传送数据和释放连接 3 个阶段。具体过程如下：

(1) 建立 TCP 连接。

(2) 客户端向 FTP 服务程序发送 USER 命令以表示用户自己的身份，然后服务程序要求客户端输入密码。

(3) 客户端发送 PASS 命令，同时将用户名密码发送给远程 FTP 服务程序。

(4) 服务端判断并通过认证。

(5) 客户端开始利用其它 FTP 协议命令进行文件操作。

(6) 结束此次连接，用 QUIT 命令退出。

2、FTPFuzz

FTPFuzz 是专门用来测试 FTP 协议安全的工具。它的基本原理就是通过对 FTP 协议中的命令及命令参数进行脏数据替换，构造畸形的 FTP 命令并发送给被测试 FTP 服务程序。

实验步骤见 PPT。

3、Fuzz DIY

实验步骤见 PPT。